

AICA LEVEL 2 · CAPSTONE PROJECT

# SurakshaScan

A DPDP readiness scanner for educational institutions

---

## Project Summary Document

Digital Personal Data Protection Act, 2023 · DPDP Rules, 2025

## CA Aditi Gulati

Deputy Director, Little Flower House Senior Secondary School & College, Varanasi

AI for Chartered Accountants — Level 2 · Batch 89, Gurugram

September 2026

## Contents

1. Executive summary
  2. The problem
  3. What SurakshaScan does
  4. Design principles
  5. Legal foundation
  6. How the AICA Level 2 syllabus is applied
  7. Technology and architecture
  8. Testing and verification
  9. Outputs
  10. Limitations
  11. Future scope
  12. How to run it
  13. Contents of this submission
-

## 1. Executive summary

Under the Digital Personal Data Protection Act, 2023, everyone below eighteen is a child. For a school, that is the entire student body. The school is the **Data Fiduciary** — responsible for every item of that data, including what its ERP vendor, fee gateway and learning platform do with it.

Most schools do not know what personal data they hold, where it sits, or which of the Act's obligations already bind them. SurakshaScan is a desktop tool that answers those questions with evidence.

It reviews a school against **25 obligations** drawn from the Act and the DPDP Rules, 2025, across **four surfaces**: the public website, the published privacy policy, supporting documents such as the admission form and consent slip, and a 26-line internal-practices working paper. It produces a scored Word report, an Excel workbook, a mobile-friendly HTML dashboard and a timestamped evidence file.

**The central design decision:** every rating comes from a deterministic rules engine, so the same inputs always produce the same score. An optional AI layer adds quoted evidence and drafting help, but it can never change a rating — and any AI finding whose quotation does not appear in the policy is rejected in print.

| Measure              | Result                                                               |
|----------------------|----------------------------------------------------------------------|
| Obligations assessed | 25, across 7 domains, each with its provision and commencement date  |
| Surfaces reviewed    | Website · privacy policy · supporting documents · internal practices |
| Working paper        | 26 lines across 5 tabs, audit working-paper conventions              |
| Code                 | About 5,800 lines of Python across 26 modules                        |
| Tests                | 42 automated tests, all passing, run offline against fixtures        |
| Outputs              | Word report · Excel workbook · HTML dashboard · evidence JSON        |

## 2. The problem

A school is unusual among Data Fiduciaries in three ways, and each one makes the DPDP Act harder for it than for a typical business.

- **Its Data Principals are children.** Section 9 requires verifiable parental consent before processing a child's data, and prohibits tracking, behavioural monitoring and targeted advertising directed at children.
- **Its website is its front door.** Admission enquiry forms, galleries of students, result boards and third-party scripts all sit on a public site that is usually built and forgotten by a vendor. It is the first thing a parent, or the Board, will look at.
- **It believes it is exempt.** Rule 12 read with Part A of the Fourth Schedule does exempt an educational institution from sections 9(1) and 9(3). Most schools read that far and stop.

### The point most schools miss

The Fourth Schedule exemption is **purpose-bound**. It covers academic activities, tracking and behavioural monitoring, and the safety of enrolled students — and nothing else. It does not reach a promotional photograph, an alumni database, a prospective student who has not enrolled, or an

advertising pixel on a public web page. Getting that boundary right is most of the value SurakshaScan adds.

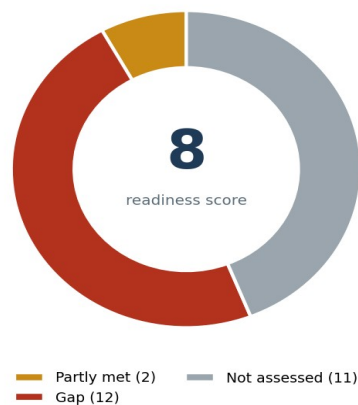
### 3. What SurakshaScan does

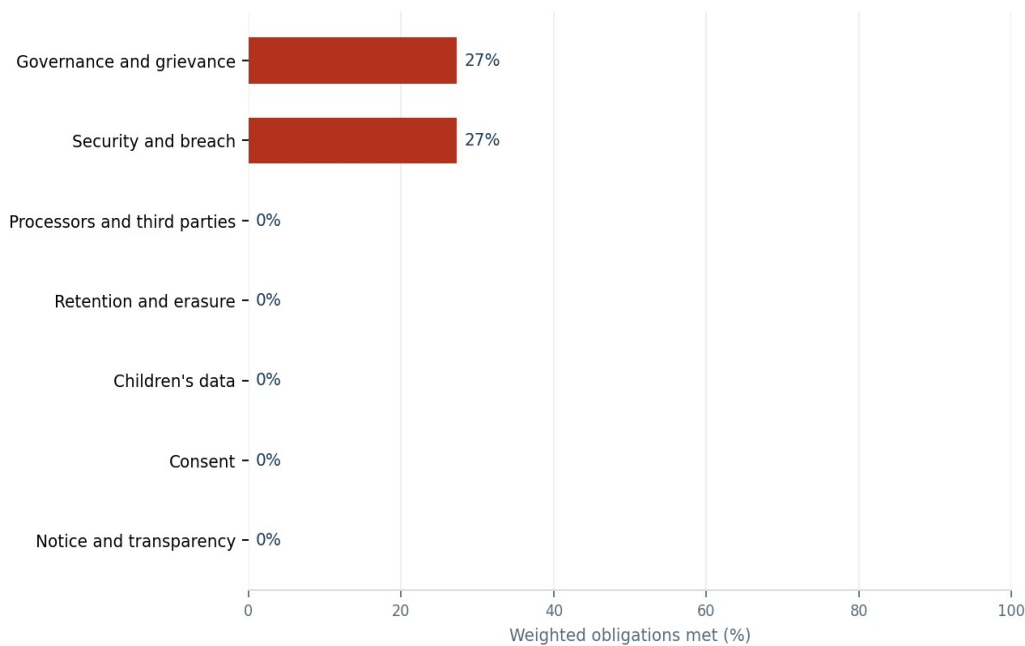
| Surface            | What is examined                                                                   | How                                                                             |
|--------------------|------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| Website            | Forms and the data they ask for, trackers, HTTPS, contact details, consent wording | A polite crawler that obeys robots.txt, rate-limits itself and never logs in    |
| Privacy policy     | Whether the notice meets section 5 and Rule 3                                      | Found and read, not just linked to; matched against the obligation catalogue    |
| Documents          | Admission form, consent slip, CCTV signage                                         | Read offline from a PDF text layer, or by a vision model with uncertainty flags |
| Internal practices | System register, vendor contracts, retention, breach procedure, media consent      | A 26-line working paper with mandatory reviewer and neutral remarks             |

For every contested finding, a two-perspective panel sets out the school's position and the parent's or the Board's position on identical facts — and what actually decides it.

#### A sample result

Run against the built-in demonstration school, SurakshaScan returns a score of **8/100 (Critical)**, with 62% of the catalogue assessable. It always reports coverage beside the score: a high score over a thin scan is not a well-run school.





## 4. Design principles

Five decisions shape the whole tool. Each is enforced in code, and each has tests that fail if it is broken.

1. **The rules engine is authoritative; the AI is advisory.** Same website, same working paper, same score. The AI layer adds quoted evidence and drafting help and cannot change a rating.
2. **The AI cannot claim what it cannot quote.** A positive AI finding must quote a passage that appears word-for-word in the policy, or it is rejected — and the rejection is printed in the report.
3. **It reads public pages only, politely.** The crawler obeys robots.txt, rate-limits itself, never logs in and never submits a form. It records what it saw, not the personal data of anyone on the page.
4. **It keeps secrets out of the evidence.** API keys and tokens are redacted before the evidence file is written, and every report names the evidence file it came from.
5. **It records who authorised the review.** The tool refuses to run until the name and designation of the authorising person is entered, and prints it on every report.

### Why the authorisation matters

Section 3(c)(ii) exempts publicly available data only where it was made public by the Data Principal, or by someone under a legal obligation to publish it. A school publishing a child's photograph on its website is neither. So that photograph stays fully within the Act, and a reviewer collecting it without the school's consent would become a **Data Fiduciary with no lawful basis**. Every external review in this project was carried out with the written authorisation of the school's principal.

## 5. Legal foundation

Each obligation carries the section or rule it comes from, the date that provision commences, and a weight reflecting its importance to a school.

| Domain                       | Obligations | Weight | Examples                                                                                  |
|------------------------------|-------------|--------|-------------------------------------------------------------------------------------------|
| Notice and transparency      | 6           | 28     | Notice published; categories itemised; withdrawal route; Board complaint route            |
| Consent                      | 3           | 13     | Affirmative action; data minimisation; auditable records                                  |
| Children's data              | 4           | 26     | Verifiable parental consent; s.9(3) tracking ban; Fourth Schedule boundary; media consent |
| Security and breach          | 3           | 17     | HTTPS; reasonable safeguards; breach procedure                                            |
| Retention and erasure        | 2           | 10     | Retention schedule; CCTV and biometric rules                                              |
| Governance and grievance     | 4           | 20     | Published contact; grievance route; record of processing                                  |
| Processors and third parties | 3           | 14     | Vendor contracts; trackers disclosed; cross-border position                               |

## Commencement

The DPDP Rules, 2025 were notified on 13 November 2025 and commence in three phases. The Act's own duties — sections 5, 6 and 8 — bind now. SurakshaScan labels every finding accordingly, so what is due today is never confused with what is due later.

| Phase | Date             | Rules                                                                        |
|-------|------------------|------------------------------------------------------------------------------|
| 1     | 13 November 2025 | Rules 1, 2 and 17–21 (definitions, the Board, appeals)                       |
| 2     | 14 November 2026 | Rule 4 (Consent Managers)                                                    |
| 3     | 14 May 2027      | Rules 3, 5–16 and 22 (notice, security, breach, retention, children, rights) |

## 6. How the AICA Level 2 syllabus is applied

The capstone is one working tool, not five exercises. Each day's learning is carried into a specific part of it.

| Day | Learning                                                              | Where it appears in SurakshaScan                                                                                                                                                 |
|-----|-----------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1   | Structured prompting; reusable skills; scheduling; separate approvals | Role + Context + Objective + Format + Examples prompt with few-shot; a packaged DPDP review skill; a quarterly re-scan that queues results for a person rather than sending them |
| 2   | Computer vision; comparing two perspectives                           | Review of admission forms, consent slips and signage photographs with uncertainty flags; the two-perspective panel for every contested finding                                   |
| 3   | Python; desktop applications; PyInstaller                             | BeautifulSoup, python-docx, openpyxl, matplotlib, PyMuPDF and Tkinter; a standalone Windows executable                                                                           |
| 4   | Business applications; audit working paper; dashboards                | Tabbed working paper with Completed / In Progress / Pending / NA, mandatory reviewer, neutral remark; donut and bar charts; Word, Excel and HTML exports                         |
| 5   | MCP; workflow automation                                              | An MCP server, read-only by default, with write tools only behind an                                                                                                             |

| Day | Learning | Where it appears in SurakshaScan                                                       |
|-----|----------|----------------------------------------------------------------------------------------|
|     |          | explicit switch and a fixed folder; an n8n trigger → action → review → output workflow |

**Deliberately held back.** A reader for the school's own social media posts and a read-only check of ERP, fee-software and TallyPrime records were built and tested during development. Real exports arrived in too many formats to make them reliable in the time available, so they were removed from the capstone build and archived for a later hackathon version. The capstone does one thing well: it scans the school website and produces the reports.

**The running themes** — data safety, verification, separate approvals, reusability, compliance, narrow permissions and audit trail — are mapped module by module in *05\_Supporting\_Documents/02\_Five\_Day\_Syllabus\_Map.md*.

## 7. Technology and architecture

Four front ends — the desktop app, the command line, an MCP server and an n8n workflow — all call one orchestration engine, so a result cannot depend on which door it came through.

| Layer              | Components                                                                                                                   |
|--------------------|------------------------------------------------------------------------------------------------------------------------------|
| Interface          | Tkinter desktop app (6 tabs) · command line · MCP server · n8n workflow                                                      |
| Evidence gathering | Website crawler · policy finder and reader · tracker detector · form and field catalogue · document vision                   |
| Assessment         | Obligation catalogue · deterministic rules engine · working-paper overlay · optional AI layer with anti-hallucination guards |
| Analysis           | Weighted scoring with coverage · prioritised remediation · two-perspective panels                                            |
| Output             | Word report · Excel workbook · HTML dashboard · evidence JSON with secrets redacted                                          |
| Libraries          | requests, BeautifulSoup, python-docx, openpyxl, matplotlib, PyMuPDF, Pillow, Tkinter, PyInstaller                            |

## 8. Testing and verification

SurakshaScan has **42 automated tests**, all passing, run entirely offline against fixture websites. They cover the scanner, the rules engine, scoring, the AI guards, every report, the authorisation requirement, the capstone scope itself, and a headless build of the desktop window.

Several tests exist to prove the tool will not do something:

- the AI layer cannot assert an obligation is met without quoting real text, or invent an obligation;
- no API key or token can reach the evidence file;
- no web page is fetched before the authorisation is checked;
- a working-paper line cannot be marked Completed without a reviewer.

## What testing found

Using the tool on real school websites surfaced defects the unit tests did not. A Meta pixel matching three signatures was being counted three times. Three argument panels were word-for-word identical. The policy finder looked for policy pages relative to the current page rather than the site root, and a retry pause was hanging the scan. Each was fixed and given a regression test. Testing also showed that social media and ERP exports were not yet reliable across formats — which is why that part was held back rather than shipped half-working.

## 9. Outputs

| Output         | For                      | Contents                                                                                                                                                                |
|----------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Word report    | The management committee | Overview with score and charts; prioritised actions; findings by obligation; two-perspective panels; working paper; documents; chatbots and AI layer; evidence appendix |
| Excel workbook | Whoever does the work    | Findings, remediation plan with blank Owner / Target date / Done columns, working paper, trackers, evidence log                                                         |
| HTML dashboard | A principal on a phone   | Single self-contained file, charts embedded, no internet needed, collapses to one column on mobile                                                                      |
| Evidence file  | An auditor, months later | Timestamped JSON of everything the scan saw and concluded, secrets redacted                                                                                             |

## 10. Limitations

- **Public surfaces only.** The website scan never logs in. Internal practice is covered by the working paper, which depends on honest answers.
- **Website only.** Social media and the school's ERP, fee software and accounts are where much of its children's data actually lives. This build does not review them; the report says so rather than implying a clean result.
- **Unsigned executable.** Windows Smart App Control blocks unsigned apps outright. A code-signing certificate would resolve this; until then the tool also runs from source.
- **A young law.** Commencement dates and the Fourth Schedule wording should be re-verified against the notified text before any report is relied upon.

## 11. Future scope

- **Hackathon build:** review of the school's own social media posts (never scraped, captions only, never faces), and a read-only check of the ERP, fee software and TallyPrime masters that reads column structure, never the children in it.
- A signed, installable Windows build.
- A multi-school benchmark that stores only aggregate scores, never identifiers.

## 12. How to run it

**Without Python:** double-click *SurakshaScan.exe* in *04\_Executable\_Files*.

**From source:**

```

pip install -r requirements.txt
python -m surakshascan.tools.demo      # offline self-test
python run.py                          # the desktop app

```

The self-test scans the bundled demonstration school, writes all three reports and checks six findings. If it prints "Self-test passed", the installation works.

## 13. Contents of this submission

| Folder                      | Contents                                                                                                                          |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| 01_Project_Summary_Document | This document                                                                                                                     |
| 02_Prompt_Files             | The policy-analysis prompt, the vision prompt, the reusable DPDP review skill, and the development prompts used to build the tool |
| 03_Example_Files            | A sample school website, and the outputs SurakshaScan produced from it (Word, Excel, dashboard, evidence file)                    |
| 04_Executable_Files         | SurakshaScan.exe and the complete source code with build instructions                                                             |
| 05_Supporting_Documents     | Architecture, syllabus map, obligation catalogue, module guides, the n8n workflow, and the version 1 baseline                     |

---

**Disclaimer.** SurakshaScan performs a readiness review. It is not a certificate of compliance with the Digital Personal Data Protection Act, 2023 or the Digital Personal Data Protection Rules, 2025, and it is not legal advice. All sample outputs in this submission are from a fictitious demonstration school.